XOR SECURE CLOUD

Phụ lục đối chiếu yêu cầu và phương án bảo đảm an ninh mạng

Kèm theo hồ sơ đề xuất cấp độ 4 hệ thống XOR SECURE CLOUD

Nền tảng XOR STACK CLOUD dựa trên OpenStack

DC tại Trung tâm Hạ tầng IDC Cầu Giấy
DR tại Trung tâm Hạ tầng IDC Nam Thăng Long

Bản dự thảo 2.1 ngày 17 tháng 10 năm 2026

Phụ lục ánh xạ 119 điểm kiểm tra tới các tiểu mục đánh số tại Điều 6.1–6.18 và Phụ lục A.4 TCVN 14423:2026. Các ý nhỏ được diễn giải trong cùng dòng hoặc tách theo nội dung. Khi kết luận, người đánh giá phải đối chiếu đầy đủ từng ý trong bản tiêu chuẩn được cấp phép; phần diễn giải không thay thế văn bản nguồn.

Phương án tại cột thứ ba là nội dung đề xuất để triển khai/đối chiếu. Chưa có kiểm soát nào được xác nhận đầy đủ trong bản dự thảo. Mỗi dòng có chỗ điền hiện trạng và mã bằng chứng; cập nhật từ Bộ 1 sau khi kiểm tra, không chỉ ghi “đã có” hoặc tên sản phẩm.

Thông tin chung	Nội dung
Phạm vi	Cả DC Cầu Giấy và DR Nam Thăng Long cùng toàn bộ dịch vụ quản trị chung.
Người lập	[CẦN ĐIỀN]
Người kiểm tra	[CẦN ĐIỀN]
Bản dựng và ngày chốt	[CẦN ĐIỀN]
Quy tắc kết luận	Đạt / Không đạt / Chưa đủ bằng chứng / Không áp dụng có căn cứ và phê duyệt.

6 1 Rủi ro

Đầu mối đề xuất: GRC và chủ quản. Phạm vi hiện trạng: [CẦN XÁC NHẬN cả hai IDC và dịch vụ áp dụng].

Mã và nguồn	Nội dung đối chiếu	Phương án tại XOR và hiện trạng	Bằng chứng và kết quả
TC-001 6.1.2.1 tr.58	Quy trình rủi ro Có quy trình xác định, phân tích, đánh giá, xử lý; rà soát ít nhất hằng năm và khi thay đổi.	Ban hành QT01 cho nền tảng, tenant và dịch vụ chung; phân công người phê duyệt rủi ro. Hiện trạng: [CẦN ĐIỀN].	Quy trình đã ký; lịch sử sửa đổi; biên bản rà soát. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-002 6.1.2.2 tr.58	Nhận diện rủi ro Nhận diện cả rủi ro nội bộ và nhà cung cấp ít nhất 1 lần/6 tháng, khi thay đổi liên quan.	Lập sổ rủi ro DC, DR, XOR STACK, IDC, ISP và chuỗi phần mềm. Hiện trạng: [CẦN ĐIỀN].	Sổ rủi ro; đầu vào CVE; đánh giá IDC/ISP. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-003 6.1.2.3 tr.58	Đánh giá tác động Phân tích khả năng, tác động, quyết định xử lý hoặc chấp nhận; đánh giá lại khi thay đổi.	Thực hiện BIA theo từng dịch vụ; phân tích ảnh hưởng khách hàng và lợi ích công cộng. Hiện trạng: [CẦN ĐIỀN].	BIA; thang điểm; hồ sơ quyết định của chủ quản. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-004 6.1.2.4 tr.58	Xử lý rủi ro Có biện pháp, ứng phó rủi ro còn lại; đánh giá hiệu lực ít nhất 1 lần/6 tháng.	Gắn rủi ro với ticket khắc phục, người phụ trách, hạn và phép thử lại. Hiện trạng: [CẦN ĐIỀN].	Kế hoạch xử lý; ticket; kết quả retest; chấp nhận tồn dư. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-005 6.1.2.5 tr.59	Theo dõi rủi ro Theo dõi thay đổi khả năng, tác động, mức rủi ro, tài sản và biện pháp.	GRC cập nhật sổ rủi ro theo cảnh báo SOC và thay đổi kiến trúc. Hiện trạng: [CẦN ĐIỀN].	Phiên bản sổ rủi ro; báo cáo định kỳ. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-006 6.1.2.6 tr.59	Thông tin rủi ro Chia sẻ kết quả và thông báo kịp thời thay đổi quan trọng cho bên liên quan.	Thiết lập danh sách nhận thông tin theo phạm vi và trách nhiệm. Hiện trạng: [CẦN ĐIỀN].	Thông báo; biên bản họp; xác nhận tiếp nhận. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.

6 2 Phần cứng

Đầu mối đề xuất: Hạ tầng và IT. Phạm vi hiện trạng: [CẦN XÁC NHẬN cả hai IDC và dịch vụ áp dụng].

Mã và nguồn	Nội dung đối chiếu	Phương án tại XOR và hiện trạng	Bằng chứng và kết quả
TC-007 6.2.1; 6.2.2.1 tr.59	Danh mục phần cứng Kiểm kê toàn bộ tài sản, kể cả bên ngoài kết nối; rà soát ít nhất hằng năm; đủ IP/MAC/serial, vị trí, EOL, mục đích, chủ sở hữu; kiểm tra trước dùng và đăng ký thiết bị di động.	CMDB chung DC/DR chứa host, switch, storage, BMC, PAW và thiết bị thuê; tài sản mới có phiếu tiếp nhận. Hiện trạng: [CẦN ĐIỀN].	CMDB; rack map; biên bản bàn giao và kiểm tra; danh sách thiết bị di động. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-008 6.2.2.2 tr.59	Thiết bị chưa quản lý Có quy trình phát hiện và xử lý thiết bị trái phép ít nhất hằng quý; loại bỏ, chặn hoặc cách ly theo quyết định.	NAC và kiểm kê định kỳ; gắn ticket cho thiết bị chưa rõ chủ. Hiện trạng: [CẦN ĐIỀN].	Quy trình; kết quả phát hiện; ticket cách ly. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-009 6.2.2.3 tr.60	Rà quét tài sản Rà quét thiết bị kết nối ít nhất hằng quý và cập nhật danh mục.	So khớp discovery với Neutron, hypervisor, IPAM và CMDB. Hiện trạng: [CẦN ĐIỀN].	Báo cáo discovery có ngày; đối soát chênh lệch. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-010 6.2.2.4 tr.60	DHCP và IPAM Ghi DHCP hoặc sử dụng IPAM nếu có; rà soát nhật ký ít nhất hằng quý để cập nhật tài sản.	Lưu DHCP/Neutron/IPAM về kho log có định danh tenant. Hiện trạng: [CẦN ĐIỀN].	Cấu hình log; mẫu log; biên bản đối soát. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-011 6.2.2.5 tr.60	Thanh lý và xóa dữ liệu Có quy trình thanh lý; xóa sạch dữ liệu khi chuyển giao hoặc đổi mục đích.	Sanitize ổ đĩa, volume và thiết bị theo loại media; xác nhận hủy khóa khi phù hợp. Hiện trạng: [CẦN ĐIỀN].	Phiếu thanh lý; chứng cứ sanitize; biên bản xác nhận. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.

6 3 Phần mềm

Đầu mối đề xuất: Platform và DevSecOps. Phạm vi hiện trạng: [CẦN XÁC NHẬN cả hai IDC và dịch vụ áp dụng].

Mã và nguồn	Nội dung đối chiếu	Phương án tại XOR và hiện trạng	Bằng chứng và kết quả
TC-012 6.3.1; 6.3.2.1 tr.60	Danh mục phần mềm Kiểm kê ít nhất hằng năm; có phiên bản, bản quyền, phạm vi, EOL, người quản lý và phần mềm thực tế cài đặt.	Quản lý phiên bản XOR, OpenStack upstream, OS, agent, firmware và container theo release. Hiện trạng: [CẦN ĐIỀN].	Danh mục; SBOM; inventory máy chủ; giấy phép. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-013 6.3.2.2 tr.60–61	Phần mềm được phép Danh sách được duyệt bao gồm runtime và dịch vụ nhà cung cấp; kiểm soát cài/gỡ/thực thi trái phép; rà soát ít nhất hằng năm hoặc khi thay đổi.	Kho gói và image đã duyệt; quyền cài đặt qua ticket; ghi vết thay đổi. Hiện trạng: [CẦN ĐIỀN].	Allowlist; quyền repository; log cài đặt; phê duyệt ngoại lệ. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-014 6.3.2.3 tr.61	Hỗ trợ vòng đời Rà soát ít nhất hằng năm để phần mềm được phép còn được hỗ trợ.	Lập kế hoạch hỗ trợ bản fork XOR và bản upstream; xử lý thành phần hết hỗ trợ. Hiện trạng: [CẦN ĐIỀN].	Ma trận EOL; cam kết hỗ trợ; kế hoạch nâng cấp. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-015 6.3.2.4 tr.61	Phần mềm trái phép Phát hiện và xử lý ít nhất 1 lần/6 tháng; ngoại lệ có biện pháp giảm rủi ro; gỡ phần mềm không được chấp thuận.	Đối soát inventory với allowlist; quản lý ngoại lệ có hạn. Hiện trạng: [CẦN ĐIỀN].	Báo cáo đối soát; sổ ngoại lệ; ticket gỡ. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.

6 4 Dữ liệu

Đầu mối đề xuất: Chủ dữ liệu và bảo mật. Phạm vi hiện trạng: [CẦN XÁC NHẬN cả hai IDC và dịch vụ áp dụng].

Mã và nguồn	Nội dung đối chiếu	Phương án tại XOR và hiện trạng	Bằng chứng và kết quả
TC-016 6.4.2.1 tr.61–62	Quy định quản lý dữ liệu Quy định phân loại, chủ sở hữu, xử lý, lưu giữ, hủy và thay đổi dữ liệu; kiểm tra phân quyền ít nhất hằng quý; rà soát quy định hằng năm/khi thay đổi.	Phân loại dữ liệu nền tảng và tenant; gắn chính sách truy cập và retention theo loại. Hiện trạng: [CẦN ĐIỀN].	Quy định; danh mục phân loại; biên bản rà soát quyền. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-017 6.4.2.2 tr.62	Danh mục dữ liệu Lập và cập nhật danh mục ít nhất hằng năm hoặc khi có thay đổi.	Liệt kê DB nền tảng, bí mật, log, ảnh, volume, backup và dữ liệu khách hàng theo phạm vi. Hiện trạng: [CẦN ĐIỀN].	Danh mục dữ liệu có phiên bản. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-018 6.4.2.3 tr.62	Quyền trên dữ liệu Có danh sách quyền của từng tài khoản/nhóm đối với từng loại dữ liệu.	Ánh xạ Keystone, DB role, object ACL và tài khoản backup tới chủ thể. Hiện trạng: [CẦN ĐIỀN].	Ma trận quyền; trích cấu hình ACL/RBAC. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-019 6.4.2.4 a tr.62	Mã hóa khi lưu Bảo vệ dữ liệu xác thực, nhạy cảm và quan trọng khi lưu bằng mã hóa hoặc kiểm soát rủi ro tương đương.	Mã hóa volume/object/backup và kho bí mật; mô tả các ngoại lệ và giới hạn bảo vệ. Hiện trạng: [CẦN ĐIỀN].	Cấu hình; danh mục phạm vi mã hóa; đánh giá tương đương. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-020 6.4.2.4 b c tr.62	Mã hóa khi truyền Bảo vệ dữ liệu quan trọng khi truyền; tối thiểu hai lần mã hóa hoặc kiểm soát rủi ro tương đương theo điều khoản.	Đề xuất TLS ứng dụng trong kênh IPsec cho luồng quan trọng; thuyết minh từng luồng. Hiện trạng: [CẦN ĐIỀN].	Ma trận luồng; cấu hình TLS/IPsec; hồ sơ tương đương. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-021 6.4.2.4 d e tr.62	Quản lý khóa và thuật toán Có phương án chuyên dụng bảo vệ khóa và dữ liệu mã hóa; sử dụng mật mã mạnh.	Quản lý vòng đời khóa trong KMS; tách người quản trị khóa; danh mục thuật toán được phép. Hiện trạng: [CẦN ĐIỀN].	Chính sách khóa; RBAC; log luân chuyển; danh mục thuật toán. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.

Mã và nguồn	Nội dung đối chiếu	Phương án tại XOR và hiện trạng	Bằng chứng và kết quả
TC-022 6.4.2.5 tr.62	Toàn vẹn dữ liệu Có kiểm tra toàn vẹn, cảnh báo sửa đổi và khôi phục dữ liệu quan trọng.	FIM/checksum/chữ ký phù hợp từng loại; đối chiếu bản sao tin cậy. Hiện trạng: [CẦN ĐIỀN].	Cấu hình FIM; cảnh báo; biên bản khôi phục. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-023 6.4.2.6 tr.62	Luồng dữ liệu Tài liệu hóa luồng và quản lý phiên bản; cập nhật ít nhất hằng năm hoặc khi thay đổi.	Duy trì DFD API, metadata, lưu trữ, log, backup và liên site. Hiện trạng: [CẦN ĐIỀN].	DFD; lịch sử sửa; phê duyệt luồng. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-024 6.4.2.7 tr.63	Phân tách dữ liệu nhạy cảm Tách xử lý/lưu trữ theo độ nhạy cảm hoặc biện pháp tương đương; bảo vệ trao đổi bằng kênh riêng hoặc tương đương.	Phân khu dữ liệu và khóa; kiểm soát xuất dữ liệu; không dùng vùng ít nhạy cảm cho dữ liệu quan trọng. Hiện trạng: [CẦN ĐIỀN].	Sơ đồ phân khu; policy; đánh giá phương án tương đương. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-025 6.4.2.8 tr.63	Chống thất thoát Triển khai kiểm soát thất thoát dữ liệu quan trọng, nhạy cảm.	DLP và hạn chế egress/export theo kênh; tích hợp SOC. Hiện trạng: [CẦN ĐIỀN].	Cấu hình; chính sách phân loại; cảnh báo thử. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-026 6.4.2.9 tr.63	Log dữ liệu quan trọng Ghi hành vi truy cập và rà soát thường xuyên, ít nhất hằng quý.	Thu DB audit/object access log/volume export và rà soát theo tenant. Hiện trạng: [CẦN ĐIỀN].	Mẫu log; biên bản rà soát; ticket bất thường. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-027 6.4.2.10 tr.63	Chữ ký số Trao đổi thông tin quan trọng dùng chữ ký số từ chủ thể có thẩm quyền hoặc nhà cung cấp được phép; bảo vệ việc sử dụng.	Xác định giao dịch cần ký số; quản lý chứng thư và thiết bị khóa; phân biệt với TLS. Hiện trạng: [CẦN ĐIỀN].	Danh sách giao dịch; chứng thư; quy trình; kết quả xác minh chữ ký. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.

6 5 Cấu hình

Đầu mối đề xuất: Platform và IT. Phạm vi hiện trạng: [CẦN XÁC NHẬN cả hai IDC và dịch vụ áp dụng].

Mã và nguồn	Nội dung đối chiếu	Phương án tại XOR và hiện trạng	Bằng chứng và kết quả
TC-028 6.5.2.1 tr.63–64	Cấu hình chuẩn Có quy trình và baseline; giao thức an toàn, host firewall, chống đăng nhập tự động vào tài sản quan trọng, vô hiệu dịch vụ thừa; hardening trước dùng; rà soát hằng năm/khi thay đổi.	Baseline riêng controller, compute, storage, network, PAW và ứng dụng XOR; theo dõi lệch cấu hình. Hiện trạng: [CẦN ĐIỀN].	Baseline; export đã che bí mật; báo cáo drift; phê duyệt ngoại lệ. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-029 6.5.2.2 tr.64	Khóa phiên Thiết lập tự khóa theo nhu cầu/rủi ro và cơ chế mở khóa khẩn cấp; các ngưỡng trong điều khoản là cấu hình có thể áp dụng.	Đề xuất PAW 15 phút, phiên quản trị 5 phút; chốt ngưỡng khóa sau đăng nhập sai và phục hồi theo đánh giá rủi ro. Hiện trạng: [CẦN ĐIỀN].	Chính sách đã chốt; cấu hình timeout; log thử và khẩn cấp. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-030 6.5.2.3 tr.64	Dịch vụ không cần thiết Có quy định gỡ hoặc vô hiệu tính năng và dịch vụ không cần thiết.	Tối thiểu hóa image OS và dịch vụ; kiểm soát package/port được phép. Hiện trạng: [CẦN ĐIỀN].	Danh sách dịch vụ; kết quả scan port; baseline. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-031 6.5.2.4 tr.64	DNS tin cậy Cấu hình DNS tin cậy trên tài sản khi có.	Resolver nội bộ có dự phòng; ACL chỉ cho DNS được duyệt. Hiện trạng: [CẦN ĐIỀN].	Cấu hình resolver; ACL; log DNS. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-032 6.5.2.5 tr.64	Xóa thiết bị từ xa Có khả năng xóa sạch từ xa đối với thiết bị di động cấp người dùng.	MDM cho thiết bị quản trị di động được cấp; thử trên thiết bị mẫu. Hiện trạng: [CẦN ĐIỀN].	Danh sách MDM; cấu hình; biên bản remote wipe. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-033 6.5.2.6 tr.64	Không gian làm việc di động Quy định tách không gian làm việc trên thiết bị di động được cấp.	Tách dữ liệu công việc/cá nhân; hạn chế sao chép theo chính sách. Hiện trạng: [CẦN ĐIỀN].	Policy MDM/work profile; cấu hình. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.

6 6 Tài khoản và quyền

Đầu mối đề xuất: IAM và bộ phận an ninh. Phạm vi hiện trạng: [CẦN XÁC NHẬN cả hai IDC và dịch vụ áp dụng].

Mã và nguồn	Nội dung đối chiếu	Phương án tại XOR và hiện trạng	Bằng chứng và kết quả
TC-034 6.6.1; 6.6.2.1 tr.65	Danh mục tài khoản Quản lý đủ tài khoản và chủ sở hữu, loại, trạng thái, tài sản, ngày kích hoạt/vô hiệu; rà soát ít nhất hằng quý; ghi log hoạt động.	Đối soát IdP, Keystone, OS, DB, network, backup và tài khoản dịch vụ. Hiện trạng: [CẦN ĐIỀN].	Danh mục; ma trận quyền; biên bản rà soát; audit log. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-035 6.6.2.2 tr.65–66	Chính sách mật khẩu Đổi mặc định; quy định độ dài, thành phần, kỳ thay và hiệu lực theo rủi ro. Điều khoản có các cấu hình tham khảo cho MFA và không MFA.	Ban hành baseline xác thực phù hợp nền tảng; chốt tham số và kiểm soát ngoại lệ; không ghi mật khẩu vào hồ sơ. Hiện trạng: [CẦN ĐIỀN].	Policy; cấu hình; thử mật khẩu; hồ sơ ngoại lệ. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-036 6.6.2.3 tr.66	Quản lý tài khoản đặc quyền PAM hoặc tương đương, quản lý tập trung, tách loại tài khoản, định danh cá nhân; quản lý khóa; xử lý mặc định; vô hiệu tài khoản không hoạt động sau 45 ngày hoặc khi thay đổi nhân sự; rà soát quy định hằng năm.	Cấp phiên PAM theo ticket, ghi phiên và JIT; tài khoản dùng chung chỉ theo ngoại lệ có truy trách nhiệm. Hiện trạng: [CẦN ĐIỀN].	Danh mục PAM; log phiên; ticket nghỉ việc; danh sách không hoạt động. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-037 6.6.2.4 tr.66	MFA và quyền tối thiểu Quyền tối thiểu, tách nhiệm vụ; MFA với truy cập ngoài tổ chức, đối tác, Internet và quyền quản trị; rà soát quy định hằng năm/khi đổi.	IdP/MFA bắt buộc cho portal quản trị, VPN và PAM; tách vận hành, bảo mật/khóa, kiểm toán. Hiện trạng: [CẦN ĐIỀN].	Ma trận RBAC; policy MFA; log thử; phê duyệt vai trò. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-038 6.6.2.5 tr.66	Cấp đổi thu hồi quyền Có quy trình cấp mới, thay đổi, thu hồi; rà soát quy trình và thực hiện ít nhất hằng năm/khi đổi.	Luồng yêu cầu → chủ tài sản duyệt → IAM thực hiện → người khác kiểm tra → lưu ticket. Hiện trạng: [CẦN ĐIỀN].	Phiếu cấp quyền; phê duyệt; kết quả thực hiện và rà soát. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.

6 7 Lỗ hổng và bản vá

Đầu mối đề xuất: SecOps và Platform. Phạm vi hiện trạng: [CẦN XÁC NHẬN cả hai IDC và dịch vụ áp dụng].

Mã và nguồn	Nội dung đối chiếu	Phương án tại XOR và hiện trạng	Bằng chứng và kết quả
TC-039 6.7.1; 6.7.2.1 tr.67	Quản lý lỗ hổng Theo dõi mối đe dọa; scan toàn hệ thống ít nhất 1 lần/6 tháng, tài sản quan trọng hằng quý; phân loại, chia sẻ, khắc phục và retest; cập nhật quy trình 6 tháng/khi đổi.	Lịch scan theo tenant/phạm vi; nguồn CVE cho upstream và fork; ưu tiên theo khả năng khai thác và tác động. Hiện trạng: [CẦN ĐIỀN].	Phạm vi scan; báo cáo; ticket; SLA nội bộ; retest. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-040 6.7.2.2 tr.67	Quản lý bản vá Quản lý tập trung; kiểm thử, đánh giá tác động và phương án phục hồi trước vá hệ thống quan trọng; kiểm tra/cập nhật máy người dùng ít nhất hằng tháng nếu có.	Kho vá nội bộ đã ký; staging trước production; cửa sổ thay đổi và rollback cho controller/compute. Hiện trạng: [CẦN ĐIỀN].	Lịch vá; bằng chứng thử; phê duyệt; inventory phiên bản. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.

6 8 Nhật ký

Đầu mối đề xuất: SOC. Phạm vi hiện trạng: [CẦN XÁC NHẬN cả hai IDC và dịch vụ áp dụng].

Mã và nguồn	Nội dung đối chiếu	Phương án tại XOR và hiện trạng	Bằng chứng và kết quả
TC-041 6.8.2.1 a tr.68	Phạm vi và trường nhật ký Thu log truy cập, tiến trình, ứng dụng, dữ liệu và cảnh báo trên toàn bộ tài sản; có nguồn/đích, định danh, thời gian, hành vi và trường phù hợp từng loại.	Lập ma trận nguồn log; chuẩn hóa actor, tenant, request ID và sự kiện quản trị XOR/OpenStack. Hiện trạng: [CẦN ĐIỀN].	Ma trận nguồn; mẫu từng loại log; parser. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-042 6.8.2.1 a tr.68	Đồng bộ và tập trung log Đồng bộ thời gian; SIEM hoặc tương đương; chuyển log về hệ thống tập trung.	NTP nội bộ dự phòng; agent/collector TLS; queue đệm và cảnh báo mất nguồn. Hiện trạng: [CẦN ĐIỀN].	Cấu hình NTP; pipeline; chứng thư; dashboard nguồn. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-043 6.8.2.1 a b tr.68	Lưu giữ và rà soát log Dung lượng lưu tối thiểu 6 tháng; theo dõi đầy kho; rà soát nhật ký ít nhất hằng tháng; cập nhật quy trình hằng năm/khi đổi.	Chính sách retention theo tháng lịch và dung lượng đo thực; quy trình rà soát SOC. Hiện trạng: [CẦN ĐIỀN].	Cấu hình retention; truy vấn log cũ; số đo EPS; báo cáo tháng. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-044 6.8.2.2 tr.69	Log nhà cung cấp Thu nhật ký an ninh của các dịch vụ nhà cung cấp có kết nối/sử dụng.	Thỏa thuận với IDC, ISP, SOC và dịch vụ dùng chung về log, phạm vi và truy xuất. Hiện trạng: [CẦN ĐIỀN].	Hợp đồng; log nhận; biên bản đối soát. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-045 6.8.2.3 tr.69	Bảo vệ nhật ký Kiểm soát và ghi lịch sử truy cập; chống sửa/xóa; kho log ở hệ thống và vùng mạng riêng; mã hóa log quan trọng nếu có.	Z08 riêng; quyền lưu/xóa tách cloud admin; bất biến hoặc cơ chế toàn vẹn tương đương. Hiện trạng: [CẦN ĐIỀN].	ACL; sơ đồ; retention lock; log thao tác kho. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.

6 9 Web và email

Đầu mối đề xuất: IT và SOC. Phạm vi hiện trạng: [CẦN XÁC NHẬN cả hai IDC và dịch vụ áp dụng].

Mã và nguồn	Nội dung đối chiếu	Phương án tại XOR và hiện trạng	Bằng chứng và kết quả
TC-046 6.9.2.1 tr.69	Trình duyệt và email Danh mục được phép, còn hỗ trợ, vá thường xuyên hoặc kiểm soát tương đương; bảo vệ thư điện tử.	Áp dụng cho máy trạm và email vận hành trong phạm vi; quản lý tập trung phiên bản. Hiện trạng: [CẦN ĐIỀN].	Danh mục; policy; phiên bản; giải pháp email. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-047 6.9.2.2 tr.69	Lọc tên miền Chặn tên miền độc hại và giả mạo bằng dịch vụ lọc tên miền.	Resolver có threat feed và log về SOC. Hiện trạng: [CẦN ĐIỀN].	Cấu hình; feed; log thử. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-048 6.9.2.3 tr.69	Lọc URL Cập nhật bộ lọc URL, hạn chế kết nối tới web độc hại/không được phép.	Proxy/secure gateway cho máy trạm được phép ra ngoài; quản trị core không ra Internet. Hiện trạng: [CẦN ĐIỀN].	Policy URL; lịch cập nhật; log. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-049 6.9.2.4 tr.69	Tiện ích mở rộng Danh sách được phép; kiểm soát cài đặt, gỡ/vô hiệu tiện ích trái phép.	Quản lý extension trình duyệt/email theo allowlist. Hiện trạng: [CẦN ĐIỀN].	Allowlist; policy; inventory extension. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-050 6.9.2.5 tr.70	Xác thực email Áp dụng DMARC để hạn chế giả mạo tên miền tổ chức.	Thiết lập SPF/DKIM/DMARC theo dịch vụ email thực tế, theo dõi báo cáo. Hiện trạng: [CẦN ĐIỀN].	DNS record; cấu hình mail; báo cáo DMARC. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-051 6.9.2.6 tr.70	Tệp đính kèm Quy định loại tệp được phép; chặn ngoài danh mục và kiểm soát thư có tệp đính kèm.	Mail gateway kiểm tra tệp theo chính sách. Hiện trạng: [CẦN ĐIỀN].	Danh sách; cấu hình; log thử. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.

6 10 Chống mã độc

Đầu mối đề xuất: SecOps. Phạm vi hiện trạng: [CẦN XÁC NHẬN cả hai IDC và dịch vụ áp dụng].

Mã và nguồn	Nội dung đối chiếu	Phương án tại XOR và hiện trạng	Bằng chứng và kết quả
TC-052 6.10.1; 6.10.2.1 tr.70	Bảo vệ mã độc Có quy định chống mã độc; bảo vệ tài sản và điểm kết nối; máy chủ/máy người dùng có bảo vệ thời gian thực, hành vi, cập nhật tự động hoặc tương đương.	EDR tương thích KVM/controller/storage; ghi nhận ngoại lệ kỹ thuật và bù trừ. Hiện trạng: [CẦN ĐIỀN].	Policy; độ phủ; phiên bản agent; ngoại lệ. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-053 6.10.2.2 tr.70	Thiết bị lưu trữ ngoài Quét media di động và vô hiệu tự thực thi.	Kiểm soát USB trên PAW và máy vận hành. Hiện trạng: [CẦN ĐIỀN].	Policy; log cắm thiết bị và scan. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-054 6.10.2.3 tr.70	Quản lý chống mã độc tập trung Quản lý cập nhật, cảnh báo và cấu hình tập trung.	Console SecOps độc lập quyền cloud admin; cảnh báo agent mất liên lạc. Hiện trạng: [CẦN ĐIỀN].	Console; chính sách; log cập nhật. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-055 6.10.2.4 tr.70	Chống khai thác Bật khả năng chống khai thác lỗ hổng trên tài sản nếu có.	Bật tính năng tương thích và đánh giá tác động hiệu năng. Hiện trạng: [CẦN ĐIỀN].	Cấu hình; ma trận tương thích; thử nghiệm. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-056 6.10.2.5 tr.71	Phát hiện hành vi EDR hoặc tương đương trên máy chủ/máy người dùng, gửi SIEM và cảnh báo thời gian thực.	Luồng agent → console → SIEM; playbook cô lập có kiểm soát. Hiện trạng: [CẦN ĐIỀN].	Mẫu sự kiện; rule; ticket phản ứng. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.

6 11 Sao lưu

Đầu mối đề xuất: Backup và Platform. Phạm vi hiện trạng: [CẦN XÁC NHẬN cả hai IDC và dịch vụ áp dụng].

Mã và nguồn	Nội dung đối chiếu	Phương án tại XOR và hiện trạng	Bằng chứng và kết quả
TC-057 6.11.2.1 tr.71	Quy trình sao lưu Định nghĩa dữ liệu, tần suất, phương pháp, kho, thử khôi phục; gồm cấu hình, ảnh OS, DB và nghiệp vụ; sẵn sàng cao; rà soát hằng năm/khi đổi.	Backup cả control plane, cấu hình SDN, image, dữ liệu dịch vụ và khóa phục hồi; chốt RPO/RTO qua BIA. Hiện trạng: [CẦN ĐIỀN].	Policy; catalog job; bản đồ phụ thuộc; BIA. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-058 6.11.2.2 tr.71	Sao lưu tự động Phân loại lịch và tự động sao lưu theo từng loại dữ liệu.	Job có giám sát lỗi, dung lượng và lần thành công gần nhất. Hiện trạng: [CẦN ĐIỀN].	Lịch job; log; cảnh báo thất bại. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-059 6.11.2.3 tr.71–72	Bảo vệ bản sao Áp dụng 3-2-1 hoặc tương đương; mã hóa bản sao dữ liệu quan trọng, nhạy cảm.	Bản sao độc lập, có bản ngoài miền lỗi chung; tài khoản/khóa sao lưu riêng. Hiện trạng: [CẦN ĐIỀN].	Sơ đồ bản sao; quyền; cấu hình mã hóa; đánh giá tương đương. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-060 6.11.2.4 tr.72	Kho sao lưu tách biệt Định danh, quản lý phiên bản và lưu trên hạ tầng độc lập với môi trường vận hành.	Z09 riêng; không chỉ giữ snapshot trên cùng cụm sản xuất; khóa và quyền xóa riêng. Hiện trạng: [CẦN ĐIỀN].	Inventory repository; sơ đồ; versioning; ACL. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-061 6.11.2.5 tr.72	Kiểm thử khôi phục Có phương án toàn vẹn; kiểm tra phục hồi bản sao ít nhất 1 lần/6 tháng.	Restore vào vùng cô lập; kiểm tra dữ liệu, ứng dụng và phụ thuộc khóa; lưu số đo. Hiện trạng: [CẦN ĐIỀN].	Biên bản restore; checksum; log và thời gian. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.

6 12 Hạ tầng mạng

Đầu mối đề xuất: Network và Platform. Phạm vi hiện trạng: [CẦN XÁC NHẬN cả hai IDC và dịch vụ áp dụng].

Mã và nguồn	Nội dung đối chiếu	Phương án tại XOR và hiện trạng	Bằng chứng và kết quả
TC-062 6.12.2.1 tr.72	Hồ sơ kiến trúc mạng Có thiết kế tổng thể, chi tiết, phương án bảo vệ; chuyên môn đánh giá trước triển khai; phân vùng, quyền tối thiểu, HA, phân đoạn vi mô hoặc tương đương; rà soát 6 tháng/khi đổi.	Duy trì HLD/LLD 12 vùng; quản lý phiên bản và quyền đọc tài liệu; kiểm tra route thực tế. Hiện trạng: [CẦN ĐIỀN].	As-built; sơ đồ vật lý/lô-gic; review; ma trận kết nối. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-063 6.12.2.2 a tr.73	Dự phòng mạng và Internet Dự phòng kết nối máy chủ, cân bằng tải và dự phòng nóng thiết bị chính; nếu cần Internet, ít nhất hai luồng quốc tế từ ISP trong nước có hạ tầng khác nhau.	Dual NIC/fabric, FW/LB HA, hai ISP; xác minh tuyến cáp và miền lỗi. Hiện trạng: [CẦN ĐIỀN].	Hợp đồng; topology; cấu hình HA; biên bản failover. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-064 6.12.2.2 a tr.73	Tường lửa và IPS FW có chống xâm nhập hoặc tương đương giữa các vùng; kiểm soát mã độc trên môi trường mạng.	NGFW/IPS tại Z01 và ranh giới phù hợp; cập nhật chữ ký, giám sát tải. Hiện trạng: [CẦN ĐIỀN].	Rule; signature; log; capacity. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-065 6.12.2.2 a tr.73	Bảo vệ CSDL DBF hoặc phương án tương đương cho CSDL tập trung.	Kiểm soát truy vấn, audit, quyền và phát hiện bất thường với DB nền tảng/DBaaS thuộc trách nhiệm XOR. Hiện trạng: [CẦN ĐIỀN].	Thiết kế DBF/DAM/tương đương; audit; rule. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-066 6.12.2.2 a tr.73	Kiểm soát lớp mạng NAC hoặc tương đương quản lý thiết bị đầu cuối kết nối; giám sát tập trung.	802.1X/NAC hoặc kiểm soát cổng/thiết bị theo rủi ro; monitoring tập trung. Hiện trạng: [CẦN ĐIỀN].	Policy; danh sách thiết bị; log; sơ đồ. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-067 6.12.2.2 a tr.73	WAF và chống DDoS Bảo vệ ứng dụng web nếu có; chống từ chối dịch vụ bằng dịch vụ/giải pháp hoặc tương đương.	Bảo vệ portal/API công khai tại DMZ; chỉ nhận origin qua WAF; phối hợp ISP chống DDoS. Hiện trạng: [CẦN ĐIỀN].	Policy; origin ACL; hợp đồng; kịch bản thử. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.

Mã và nguồn	Nội dung đối chiếu	Phương án tại XOR và hiện trạng	Bằng chứng và kết quả
TC-068 6.12.2.2 a tr.73	Biên vùng lõi ít tin cậy Datadiode/USG/BSG hoặc kiểm soát rủi ro tương đương cho vùng lõi/OT với vùng ít tin cậy.	Lập hồ sơ luồng một chiều/hai chiều, giới hạn giao thức và xác minh phương án tương đương. Hiện trạng: [CẦN ĐIỀN].	DFD; đánh giá rủi ro; thiết kế cổng; kết quả thử. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-069 6.12.2.2 a tr.73	Duy trì hạ tầng mạng Cập nhật phát hiện tấn công; quản lý thay đổi/kết nối/gỡ thiết bị; theo dõi hiệu năng; bảo vệ Wi-Fi nếu có.	Thay đổi qua ticket, cập nhật rule, giám sát CPU/RAM/băng thông; tách Wi-Fi nếu tồn tại. Hiện trạng: [CẦN ĐIỀN].	Ticket; báo cáo capacity; chính sách Wi-Fi; cập nhật rule. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-070 6.12.2.2 b tr.73–74	Phân vùng theo chức năng Tách nội bộ, biên, máy chủ nội bộ, DMZ, CSDL, quản trị thiết bị và quản trị; WAN/Wi-Fi nếu có.	Ánh xạ Z01–Z12; phân khu storage, API, DB, queue và OOB; không coi một VPC là đủ. Hiện trạng: [CẦN ĐIỀN].	VLAN/VRF/VXLAN; SG; route; sơ đồ. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-071 6.12.2.3 tr.74	Giao thức an toàn Chỉ sử dụng giao thức truyền thông và quản trị an toàn theo điều khoản.	Chốt phiên bản TLS/SSH và bộ mật mã phù hợp bản dựng; tắt giao thức yếu. Hiện trạng: [CẦN ĐIỀN].	Cấu hình; báo cáo kiểm tra TLS/SSH. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-072 6.12.2.4 tr.74	Quy tắc truy cập mạng Xác thực, kết nối an toàn, allowlist vào/ra theo dịch vụ; timeout, giới hạn kết nối theo năng lực, kiểm soát nội bộ và egress máy chủ.	Default deny; rule có owner, ticket và thời hạn; egress qua điểm kiểm soát. Hiện trạng: [CẦN ĐIỀN].	Ma trận luồng; rule export; cấu hình timeout/rate. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-073 6.12.2.5 tr.74–75	Quản trị từ xa VPN/ZTNA hoặc tương đương; MFA và xác thực bổ sung; giới hạn nguồn/thiết bị; quản trị gián tiếp và endpoint được bảo vệ.	PAW → gateway Z01 → PAM Z06 → đích được duyệt; không route toàn mạng. Hiện trạng: [CẦN ĐIỀN].	Policy; cấu hình; log PAM; trạng thái EDR. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-074 6.12.2.6 tr.75	Mạng quản trị chuyên dụng Tài nguyên quản trị tách vật lý/lô-gic với mạng chính và không kết nối Internet.	Z06/Z10 riêng; không egress Internet; bản vá nhập qua kho trung chuyển kiểm tra. Hiện trạng: [CẦN ĐIỀN].	Route; ACL; topology; quy trình nhập gói. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-075 6.12.2.7 tr.75	Kiểm thử và nghiệm thu Có kế hoạch, thử trước bàn giao/vận hành, giám sát độc lập; báo cáo được chuyên trách xác nhận và chủ quản duyệt.	Tổ chức T01–T12; bằng chứng cấu hình và retest kèm biên bản. Hiện trạng: [CẦN ĐIỀN].	Kế hoạch; phân công độc lập; biên bản; phê duyệt. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.

6 13 Giám sát

Đầu mối đề xuất: SOC. Phạm vi hiện trạng: [CẦN XÁC NHẬN cả hai IDC và dịch vụ áp dụng].

Mã và nguồn	Nội dung đối chiếu	Phương án tại XOR và hiện trạng	Bằng chứng và kết quả
TC-076 6.13.2.1 tr.75	Giám sát tập trung 24 trên 7 Giám sát thiết bị, máy chủ, ứng dụng, dịch vụ; liên kết sự kiện bằng SIEM; bố trí nguồn lực 24/7.	SOC có ca trực, escalation, người thay ca và phạm vi nguồn log hai IDC. Hiện trạng: [CẦN ĐIỀN].	Lịch trực; SLA; use case; ticket; log bàn giao. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-077 6.13.2.2 tr.75	Tính năng phòng vệ hệ thống Bật firewall/phát hiện/ngăn chặn xâm nhập của OS/hệ thống nếu có.	Host firewall, agent và FIM theo baseline đã kiểm thử tương thích. Hiện trạng: [CẦN ĐIỀN].	Baseline; agent state; log. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-078 6.13.2.3 tr.76	Cổng kết nối và quản trị Kiểm soát cổng thiết bị nếu hỗ trợ; tách cổng quản trị ứng dụng với cổng dịch vụ.	Admin endpoint riêng, ACL qua PAM; port security trên switch/SDN. Hiện trạng: [CẦN ĐIỀN].	Port map; cấu hình; endpoint catalog. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-079 6.13.2.4 tr.76	Dữ liệu mạng Thu flow log và/hoặc lưu lượng để rà soát, cảnh báo.	Thu NetFlow/IPFIX/SDN flow hoặc cảm biến phù hợp; bảo vệ dữ liệu thu. Hiện trạng: [CẦN ĐIỀN].	Cấu hình exporter; mẫu flow; rule. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-080 6.13.2.5 tr.76	Điều chỉnh cảnh báo Rà soát ngưỡng cảnh báo ít nhất hằng quý.	SOC đánh giá false positive và ca bỏ sót, có phê duyệt thay đổi rule. Hiện trạng: [CẦN ĐIỀN].	Biên bản quý; phiên bản rule; kết quả thử. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.

6 14 Nhân sự

Đầu mối đề xuất: Nhân sự và chủ quản. Phạm vi hiện trạng: [CẦN XÁC NHẬN cả hai IDC và dịch vụ áp dụng].

Mã và nguồn	Nội dung đối chiếu	Phương án tại XOR và hiện trạng	Bằng chứng và kết quả
TC-081 6.14.1; 6.14.2.1 tr.76	Tổ chức và độc lập chuyên môn Có bộ phận vận hành, quản trị và bảo vệ an ninh riêng; độc lập chuyên môn; nhân sự đủ năng lực.	Quyết định giao nhiệm vụ và RACI; kiểm soát xung đột quyền. Hiện trạng: [CẦN ĐIỀN].	Sơ đồ tổ chức; quyết định; hồ sơ năng lực; ma trận quyền. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-082 6.14.2.2 tr.76	Nhận thức và nghỉ việc Đào tạo toàn bộ người dùng ít nhất hằng năm; khi đổi/nghỉ việc thu hồi tài sản, quyền vật lý/lô-gic, có cam kết bảo mật.	Onboarding/offboarding nối HR với IAM/IDC/IT; đào tạo nhận thức và kiểm tra. Hiện trạng: [CẦN ĐIỀN].	Danh sách học; kết quả; NDA; phiếu thu hồi. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-083 6.14.2.3 tr.77	Đào tạo theo vai trò Đào tạo chuyên môn và trách nhiệm pháp lý ít nhất hằng năm hoặc khi thay đổi nhân sự liên quan.	Chương trình riêng Platform, Network, SOC, phát triển và quản trị khóa. Hiện trạng: [CẦN ĐIỀN].	Kế hoạch; tài liệu; điểm kiểm tra; hồ sơ năng lực. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.

6 15 Nhà cung cấp

Đầu mối đề xuất: Mua sắm và GRC. Phạm vi hiện trạng: [CẦN XÁC NHẬN cả hai IDC và dịch vụ áp dụng].

Mã và nguồn	Nội dung đối chiếu	Phương án tại XOR và hiện trạng	Bằng chứng và kết quả
TC-084 6.15.1; 6.15.2.1 tr.77	Danh mục nhà cung cấp Kiểm kê/phân loại, ranh giới trách nhiệm; nhà cung cấp ANM đủ điều kiện theo quy định; rà soát hằng năm/khi đổi.	Danh mục IDC, ISP, SOC, phần mềm và hỗ trợ; kiểm tra pháp lý theo dịch vụ thực tế. Hiện trạng: [CẦN ĐIỀN].	Danh mục; hợp đồng; giấy tờ năng lực/điều kiện khi áp dụng. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-085 6.15.2.2 tr.77	Quy định nhà cung cấp Có quy định quản lý; rà soát hằng năm/khi đổi.	Quy định lựa chọn, đánh giá, truy cập, giám sát và kết thúc dịch vụ. Hiện trạng: [CẦN ĐIỀN].	Quy định; biên bản rà soát. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-086 6.15.2.3 tr.77	Điều khoản bảo mật Hợp đồng có yêu cầu bảo mật; rà soát khi gia hạn.	Thỏa thuận quyền truy cập, dữ liệu/log, sự cố, khôi phục, kiểm tra và chấm dứt. Hiện trạng: [CẦN ĐIỀN].	Hợp đồng/SLA/phụ lục; review pháp chế. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-087 6.15.2.4 tr.77	Theo dõi nhà cung cấp Giám sát việc thực hiện yêu cầu cung cấp dịch vụ.	Đối soát SLA, quyền truy cập, sự cố và bằng chứng định kỳ. Hiện trạng: [CẦN ĐIỀN].	Báo cáo SLA; biên bản đánh giá; ticket. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-088 6.15.2.5 tr.77	Kết thúc hợp đồng Rà soát an ninh khi chấm dứt.	Thu hồi quyền, nhận dữ liệu và log, xác nhận xóa/hoàn trả theo hợp đồng. Hiện trạng: [CẦN ĐIỀN].	Checklist kết thúc; biên bản; log thu hồi. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.

6 16 Phát triển an toàn

Đầu mối đề xuất: DevSecOps. Phạm vi hiện trạng: [CẦN XÁC NHẬN cả hai IDC và dịch vụ áp dụng].

Mã và nguồn	Nội dung đối chiếu	Phương án tại XOR và hiện trạng	Bằng chứng và kết quả
TC-089 6.16.2.1 tr.78	Quy trình phát triển Có SSDLC, rà soát hằng năm/khi đổi; phần thuê ngoài có cam kết, mã nguồn hoặc biện pháp thay thế theo điều khoản; thử và đánh giá trước dùng/khi đổi kiến trúc.	Áp dụng cho bản fork XOR, portal và API; yêu cầu release qua review, staging và phê duyệt. Hiện trạng: [CẦN ĐIỀN].	SSDLC; hợp đồng; review; release checklist; báo cáo thử. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-090 6.16.2.2 tr.78	Tiếp nhận lỗ hổng phần mềm Có kênh bên ngoài báo cáo và quy trình xử lý; rà soát hằng năm/khi đổi.	Đầu mối PSIRT/XOR tiếp nhận, phân loại, khắc phục, phản hồi. Hiện trạng: [CẦN ĐIỀN].	Quy trình; kênh liên hệ; ticket đã che dữ liệu. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-091 6.16.2.3 tr.78	Nguyên nhân lỗ hổng Phân tích nguyên nhân gốc của lỗ hổng.	Gắn RCA với defect và cập nhật rule/test để tránh tái diễn. Hiện trạng: [CẦN ĐIỀN].	RCA; ticket; thay đổi test/code. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-092 6.16.2.4 tr.78–79	Thành phần bên thứ ba Quản lý danh sách thành phần hiện tại/dự kiến và rủi ro; cập nhật ít nhất hằng quý.	SBOM theo release, nguồn gói, giấy phép, CVE và bản vá upstream. Hiện trạng: [CẦN ĐIỀN].	SBOM; SCA; catalog dependency; review quý. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-093 6.16.2.5 tr.79	Tách môi trường Tách dev/test/production; không lưu bí mật trong mã nguồn.	Project/credential/runner riêng; secret manager và dữ liệu thử đã xử lý. Hiện trạng: [CẦN ĐIỀN].	Sơ đồ; quyền CI; secret scan. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-094 6.16.2.6 tr.79	Đào tạo lập trình Đào tạo phát triển an toàn phù hợp môi trường ít nhất hằng năm.	Chương trình cho Python/API/IaC/container và phần tùy biến XOR. Hiện trạng: [CẦN ĐIỀN].	Danh sách học; nội dung; bài kiểm tra. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-095 6.16.2.7 tr.79	Kiến trúc ứng dụng an toàn Kiểm tra đầu vào/ra; chống tấn công phổ biến; xử lý lỗi; quản lý phiên; không hardcode bí mật.	Threat model portal/API; validation, encoding, session và error handling theo thiết kế. Hiện trạng: [CẦN ĐIỀN].	Threat model; code review; test; secret scan. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.

Mã và nguồn	Nội dung đối chiếu	Phương án tại XOR và hiện trạng	Bằng chứng và kết quả
TC-096 6.16.2.8 tr.79	Thành phần bảo mật tin cậy Dùng mô-đun được kiểm chứng, mật mã mạnh và log hành vi người dùng.	Thư viện xác thực/mật mã có quản lý vòng đời; audit API theo request ID. Hiện trạng: [CẦN ĐIỀN].	Danh mục thư viện; review; mẫu audit. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-097 6.16.2.9 tr.79	Kiểm tra trước phát hành Kiểm tra mã nguồn/dependency; pentest và xử lý lỗ hổng trước production.	SAST/SCA/secret scan/DAST và pentest theo phạm vi; gate phát hành, retest. Hiện trạng: [CẦN ĐIỀN].	Báo cáo; waiver có hạn; phê duyệt release. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.

6 17 Ứng phó sự cố

Đầu mối đề xuất: CSIRT và SOC. Phạm vi hiện trạng: [CẦN XÁC NHẬN cả hai IDC và dịch vụ áp dụng].

Mã và nguồn	Nội dung đối chiếu	Phương án tại XOR và hiện trạng	Bằng chứng và kết quả
TC-098 6.17.2.1 tr.80	Lực lượng ứng phó Có đầu mối chính và ít nhất một dự phòng, vai trò phối hợp; xác minh liên hệ hằng năm.	Chỉ định chỉ huy, kỹ thuật, pháp chế, truyền thông và đầu mối IDC/ISP. Hiện trạng: [CẦN ĐIỀN].	Quyết định; danh bạ; lịch trực; xác minh liên hệ. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-099 6.17.2.2 tr.80	Báo cáo sự cố Có quy trình nội bộ, phân nhóm; rà soát hằng năm/khi đổi.	SOC phân loại, mở hồ sơ, báo cáo chỉ huy và chuyển tuyến theo nghĩa vụ áp dụng. Hiện trạng: [CẦN ĐIỀN].	Quy trình; mẫu báo cáo; ticket. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-100 6.17.2.3 tr.80	Quy trình ứng phó Có quy trình phối hợp cơ quan chức năng, chuyên gia, nhà cung cấp; rà soát hằng năm/khi đổi.	Playbook lộ khóa, ransomware, truy cập chéo tenant, mất DC và DDoS. Hiện trạng: [CẦN ĐIỀN].	Playbook; danh sách phối hợp; biên bản. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-101 6.17.2.4 tr.80	Kênh liên lạc dự phòng Có kênh chính/phụ; rà soát hằng năm/khi đổi.	Danh bạ và kênh ngoài nền tảng vẫn dùng được khi IAM/cloud dừng. Hiện trạng: [CẦN ĐIỀN].	Danh bạ ngoại tuyến được bảo vệ; biên bản thử. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-102 6.17.2.5 tr.80	Đánh giá sau sự cố Thực hiện đánh giá sau sự cố.	Lập timeline, nguyên nhân, tác động và hành động có owner/hạn. Hiện trạng: [CẦN ĐIỀN].	Báo cáo hậu kiểm; ticket cải tiến. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-103 6.17.2.6 tr.80	Diễn tập Có kế hoạch và diễn tập ít nhất hằng năm.	Kết hợp tabletop và thử kỹ thuật theo phạm vi đã duyệt. Hiện trạng: [CẦN ĐIỀN].	Kế hoạch; biên bản; bài học; danh sách tham dự. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-104 6.17.2.7 tr.80	Ngưỡng sự cố Thiết lập, duy trì ngưỡng và cập nhật hằng năm/khi đổi.	Định nghĩa mức nghiêm trọng theo phạm vi dữ liệu, số tenant, thời gian gián đoạn và tác động xã hội. Hiện trạng: [CẦN ĐIỀN].	Ma trận phân loại; phê duyệt; lịch sử sửa. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.

6 18 Kiểm tra an ninh

Đầu mối đề xuất: Đánh giá độc lập và GRC. Phạm vi hiện trạng: [CẦN XÁC NHẬN cả hai IDC và dịch vụ áp dụng].

Mã và nguồn	Nội dung đối chiếu	Phương án tại XOR và hiện trạng	Bằng chứng và kết quả
TC-105 6.18.2.1 tr.81	Chương trình pentest Phê duyệt phạm vi, thời gian, cách thử, đầu mối, giới hạn, bảo vệ dữ liệu và vận hành; ưu tiên môi trường phát triển/cửa sổ được duyệt.	ROE riêng cho portal/API, nội bộ, tenant isolation và đặc quyền; có dừng khẩn cấp. Hiện trạng: [CẦN ĐIỀN].	ROE; phê duyệt; danh sách mục tiêu; cam kết bảo mật. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-106 6.18.2.2 tr.81	Pentest bên ngoài Kiểm thử ứng dụng/dịch vụ công khai ít nhất hằng năm.	Pentest endpoint Internet của XOR theo FQDN/IP đã chốt. Hiện trạng: [CẦN ĐIỀN].	Báo cáo; phạm vi; ngày; retest. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-107 6.18.2.3 tr.81	Khắc phục sau pentest Xử lý tồn tại theo phạm vi và mức ưu tiên của tổ chức.	Gắn phát hiện với ticket, SLA nội bộ, chủ sở hữu và phép thử lại. Hiện trạng: [CẦN ĐIỀN].	Danh sách phát hiện; ticket; retest. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-108 6.18.2.4 tr.81	Hiệu lực kiểm soát Đánh giá lại hiệu quả biện pháp sau mỗi đợt pentest.	SOC/Platform cập nhật rule, baseline và playbook theo bài học. Hiện trạng: [CẦN ĐIỀN].	Biên bản review; rule/test bổ sung. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-109 6.18.2.5 tr.81	Pentest bên trong Kiểm thử tài nguyên nội bộ ít nhất hằng năm.	Đánh giá ranh giới quản trị, tenant, storage và dịch vụ nền trong phạm vi duyệt. Hiện trạng: [CẦN ĐIỀN].	Báo cáo nội bộ; ROE; retest. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.

A 4 An toàn vật lý

Đầu mối đề xuất: IDC và Hạ tầng XOR. Phạm vi hiện trạng: [CẦN XÁC NHẬN cả hai IDC và dịch vụ áp dụng].

Mã và nguồn	Nội dung đối chiếu	Phương án tại XOR và hiện trạng	Bằng chứng và kết quả
TC-110 A.4.1 tr.109	Vị trí phòng máy Vị trí tránh tầng cao, tầng hầm, nơi chứa nước và vùng dễ cháy/nhiễu mạnh theo điều khoản.	Khảo sát riêng IDC Cầu Giấy và IDC Nam Thăng Long; ghi vị trí thực, rủi ro và xử lý. Hiện trạng: [CẦN ĐIỀN].	Bản vẽ vị trí; biên bản khảo sát; xác nhận IDC. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-111 A.4.2 tr.109	Ra vào và camera Cổng điện tử; camera tập trung 24/7, lưu tối thiểu 6 tháng; vành đai và bảo vệ vùng thiết bị quan trọng.	Kiểm soát thẻ, khách thăm, rack và camera tại cả hai IDC. Hiện trạng: [CẦN ĐIỀN].	Quy chế; access log; mẫu camera đủ mốc; hợp đồng. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-112 A.4.3 tr.109	Chống trộm phá hoại Rack cố định, nhãn, cáp đi ngầm có bảo vệ, báo động chống trộm tự động hoặc tương đương.	Khóa rack, quản lý chìa, giám sát cửa và tuyến cáp. Hiện trạng: [CẦN ĐIỀN].	Ảnh hiện trạng; danh mục rack; biên bản thử báo động. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-113 A.4.4 tr.110	Chống sét Chống sét tòa nhà được nghiệm thu/kiểm tra; bảo vệ lan truyền điện và kết nối.	Thu hồ sơ chống sét, tiếp địa và kiểm tra định kỳ từ IDC. Hiện trạng: [CẦN ĐIỀN].	Nghiệm thu; bản vẽ; đo kiểm; bảo trì. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-114 A.4.5 tr.110	Phòng cháy Báo/chữa cháy tự động, tín hiệu cảnh báo, vật liệu chịu lửa và cách ly vùng quan trọng.	Xác minh hệ thống PCCC và phương án phối hợp tại từng IDC. Hiện trạng: [CẦN ĐIỀN].	Hồ sơ nghiệm thu; bảo trì; sơ đồ; diễn tập. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-115 A.4.6 tr.110	Chống nước Bảo vệ thoát nước, trần/cửa và chống tích tụ, thấm nước vào phòng máy.	Kiểm tra đường ống, cảm biến rò và xử lý sự cố nước tại IDC. Hiện trạng: [CẦN ĐIỀN].	Bản vẽ; biên bản khảo sát; log/cảnh báo nếu có. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-116 A.4.7 tr.110	Chống tĩnh điện Biện pháp chống tĩnh điện và sàn chống tĩnh điện.	Quy trình thao tác phần cứng và bảo trì sàn tại IDC. Hiện trạng: [CẦN ĐIỀN].	Hồ sơ vật liệu; kiểm tra; quy trình bảo trì. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.

Mã và nguồn	Nội dung đối chiếu	Phương án tại XOR và hiện trạng	Bằng chứng và kết quả
TC-117 A.4.8 tr.110	Nhiệt độ độ ẩm Điều hòa phòng máy riêng, duy trì ổn định; đo/cảnh báo độ ẩm và hút ẩm.	Giám sát môi trường 24/7, giới hạn theo thiết bị và quy trình phản ứng. Hiện trạng: [CẦN ĐIỀN].	Sơ đồ điều hòa; log nhiệt/ẩm; cảnh báo; bảo trì. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-118 A.4.9 tr.110–111	Nguồn điện Nguồn ổn định có chống quá tải; hai nguồn từ hai trạm điện khác nhau; UPS liên tục.	Xác minh đường cấp điện, trạm nguồn, UPS và đấu A/B cho rack XOR. Hiện trạng: [CẦN ĐIỀN].	Sơ đồ một sợi; xác nhận nguồn; log UPS; biên bản chuyển nguồn. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.
TC-119 A.4.10 tr.111	Bảo vệ điện từ Tách điện và tín hiệu, che nguồn nhiễu; tấm chắn điện từ vùng máy chủ quan trọng/thiết bị mạng chính.	Khảo sát tuyến cáp, thiết bị gây nhiễu và che chắn khu vực tương ứng. Hiện trạng: [CẦN ĐIỀN].	Bản vẽ; ảnh; hồ sơ vật liệu; kiểm tra của IDC. Mã BC: [CẦN ĐIỀN]. Kết quả: Chưa đủ bằng chứng.

Xác nhận kết quả đối chiếu

Tổng số điểm áp dụng: [ ]; không áp dụng có căn cứ: [ ]; đạt: [ ]; không đạt: [ ]; chưa đủ bằng chứng: [ ]. Các số liệu trên phải được tổng hợp từ kết quả đã xác nhận, kèm ngày chốt và phạm vi.

Tồn tại chưa xử lý: [CẦN ĐIỀN mã yêu cầu, ảnh hưởng, hành động, người chịu trách nhiệm, hạn và biện pháp tạm thời]. Các yêu cầu bắt buộc chưa đáp ứng không được đổi thành đạt chỉ bởi quyết định chấp nhận rủi ro.

Kết luận của người kiểm tra: [CẦN ĐIỀN kết luận trong phạm vi và giới hạn kiểm tra thực tế].

Nơi nhận:
Như trên;
Lưu: hồ sơ XOR SECURE CLOUD.

NGƯỜI CÓ THẨM QUYỀN XÁC NHẬN
(Ký, ghi rõ họ tên và đóng dấu theo thẩm quyền)

[CẦN ĐIỀN NGƯỜI KIỂM TRA ĐƯỢC PHÂN CÔNG]